



UNIVERSITÀ DEGLI STUDI DI SALERNO

Penetration Testing Report

Academy - Cybersecurity

Target: no_name

Gruppo 11

Emiddio Ferrentino - 0612708848

Daniele Manzo - 0612709599

Andrea Rossomando - 0612708971

A.A. 2025/2026

Sommario

Il presente documento illustra le metodologie, le esecuzioni e i risultati finali dell'attività di Penetration Testing condotta sull'infrastruttura virtuale denominata **no_name**.

L'attività è stata svolta in un ambiente di laboratorio isolato e strettamente controllato, con l'intento etico di valutare la resilienza dei sistemi difensivi. L'intero processo di valutazione ha seguito un approccio strutturato basato sul Framework Generale per il Penetration Testing (FGPT), articolandosi in fasi rigorose: dall'iniziale ricognizione e mappatura delle vulnerabilità (*Information Gathering*), passando per lo sfruttamento attivo delle falle individuate (*Target Exploitation*), fino all'ottenimento dei massimi privilegi di sistema (*Privilege Escalation*).

L'obiettivo di questo elaborato non è solo quello di fornire una panoramica manageriale dei rischi riscontrati, ma anche di garantire la totale riproducibilità tecnica dei test effettuati, proponendo infine un piano di *remediation* mirato e affidabile per la messa in sicurezza definitiva dell'asset.

Indice

1	Executive Summary	4
1.1	Scope del test	4
1.2	Risultati ottenuti	4
1.3	Problematiche rilevate	4
1.4	Contromisure	5
1.5	Analisi del rischio	5
1.5.1	Valutazione	5
1.5.2	Riduzione	5
2	Engagement Highlights	6
2.1	Accordi preliminari	6
2.2	Requisiti legali e operativi	6
2.3	Modalità di esecuzione del Penetration Testing	6
2.4	Metodologia adottata	6
2.5	Date di inizio e fine attività	6
2.6	Obiettivi del test	7
2.7	Ruoli, obblighi e responsabilità	7
3	Vulnerability Report	8
3.1	Command Injection - CRITICAL	8
3.1.1	Descrizione della vulnerabilità	8
3.1.2	Impatto sulla sicurezza	8
3.1.3	Valutazione esposizione	8
3.2	Local Privilege Escalation - CRITICAL	8
3.2.1	Descrizione della vulnerabilità	8
3.2.2	Impatto sulla sicurezza	9
3.2.3	Valutazione esposizione	9
3.3	CUPS - HIGH	9
3.3.1	Descrizione della vulnerabilità	9
3.3.2	Impatto sulla sicurezza	9
3.3.3	Valutazione esposizione	9
3.4	Security Misconfiguration - MEDIUM	9
3.4.1	Descrizione della vulnerabilità	9
3.4.2	Impatto sulla sicurezza	10
3.4.3	Valutazione esposizione	10
3.5	Sensitive Data Exposure - MEDIUM	10
3.5.1	Impatto sulla sicurezza	10
3.5.2	Valutazione esposizione	10
3.6	Information Disclosure - LOW	10

3.6.1	Descrizione della vulnerabilità	10
3.6.2	Impatto sulla sicurezza	11
3.6.3	Valutazione esposizione	11
4	Remediation Report	12
4.1	Obiettivo	12
4.2	Raccomandazioni di sicurezza	12
4.2.1	VULN-01: Command Injection	12
4.2.2	VULN-02: Local Privilege Escalation	12
4.2.3	VULN-03: CUPS Vulnerability	13
4.2.4	VULN-04: Security Misconfiguration	13
4.2.5	VULN-05: Sensitive Data Exposure	13
4.2.6	VULN-06: Information Disclosure	13
5	Findings Summary	14
5.1	Convenzioni e catalogazione	14
5.2	Dettaglio dei risultati	14
5.3	Grafici e visualizzazioni	15
5.4	Focus tecnico	15
5.5	Supporto alla remediation	16
6	Detailed Summary	17
6.1	Classificazione del rischio	17
6.2	Command Injection	17
6.3	Local Privilege Escalation	18
6.4	CUPS Vulnerability	18
6.5	Security Misconfiguration	19
6.6	Sensitive Data Exposure	19
6.7	Information Disclosure	20
7	Bibliografia	21

Capitolo 1

Executive Summary

Il presente documento illustra i risultati dell'attività di Penetration Testing condotta dal Gruppo 11 sulla macchina virtuale vulnerabile **no_name** ricevuta dal committente. L'obiettivo di questa sezione è fornire una panoramica generale, sintetica e non tecnica dello stato di sicurezza del sistema analizzato evidenziando i rischi di business e le azioni correttive prioritarie.

1.1 Scope del test

Il perimetro dell'attività di valutazione è stato rigorosamente limitato all'infrastruttura e ai servizi esposti dalla macchina virtuale **no_name**. L'obiettivo principale è quello di simulare un attacco informatico realistico per identificare, documentare e sfruttare tutte le vulnerabilità possibili, valutare la resilienza dei sistemi difensivi e la loro efficacia nelle configurazioni di sicurezza attuali.

1.2 Risultati ottenuti

L'attività di Penetration Testing ha ottenuto ***esito positivo*** per l'attaccante. Il team è riuscito a compromettere interamente il bersaglio, ottenendo un accesso iniziale non autorizzato e, successivamente, a prendere controllo dell'intero target con l'acquisizione mirata dei privilegi di amministratore (*root*). Attualmente, quindi, l'infrastruttura è esposta a compromissioni critiche.

1.3 Problematiche rilevate

Le criticità che hanno portato alla compromissione del sistema derivano da due macro-aree:

1. Debolezze applicative:

- **Validazione input:** Sono stati individuati gravi carenze nella validazione degli input utente all'interno dell'applicazione web, che hanno permesso l'esecuzione di codice malevolo sulla macchina target.
- **Carenze nelle policy di sicurezza web:** L'assenza di difese standard lato client espone l'interfaccia utente a manipolazioni invisibili, permettendo potenzialmente di ingannare gli operatori legittimi.

2. Misconfigurazioni di sistema e di rete:

- **Servizi obsoleti ed esposti:** La macchina target mantiene servizi di sistema esposti, noti per essere gravemente vulnerabili. Questo difetto rappresenta un *ingresso di servizio* per prendere il controllo della macchina, aggirando del tutto le difese principali dell'applicativo.
- **Fuga di informazioni tecniche:** L'infrastruttura risponde in modo troppo permissivo alle richieste da reti esterne, rivelando involontariamente informazioni sul proprio stato operativo.
- **Trapelazione informazioni sensibili:** Fuga di informazioni critiche nelle pagine web accessibili dall'utenza regolare.

1.4 Contromisure

Per ripristinare un adeguato livello di sicurezza, risolvendo tutte le problematiche descritte nella sezione precedente, si raccomanda di adottare strategie e interventi tempestivi con le seguenti azioni:

- Implementare rigorosi sistemi di controllo e validazione su tutti i dati in ingresso al web server.
- Disabilitare i servizi strettamente non necessari all'erogazione dell'applicazione web.
- Applicare il principio del **minimo privilegio** (Least Privilege), rivedendo le autorizzazioni e i permessi dei file di sistema.

1.5 Analisi del rischio

1.5.1 Valutazione

Rischio Attuale

Il rischio complessivo associato all'asset **no_name** è classificato come **CRITICO**. Le vulnerabilità scoperte permettono a un attaccante esterno, senza credenziali né permessi validi, di poter entrare nella macchina e prenderne il controllo, potendo estrarre informazioni sensibili o addirittura essenziali per il committente, manipolare il sistema o utilizzarlo come ponte per attaccare altre macchine nella rete.

1.5.2 Riduzione

Rischio Residuo Atteso

L'applicazione tempestiva delle remediation suggerite in questo documento abbatterà drasticamente la superficie d'attacco. Mitigando le vulnerabilità applicative e restringendo le configurazioni di sistema, il rischio residuo verrà riportato a un livello **BASSO** e accettabile per l'operatività aziendale.

Capitolo 2

Engagement Highlights

2.1 Accordi preliminari

Le attività di Penetration Testing sono state concordate e autorizzate nell'ambito del corso di Cybersecurity Academy (A.A. 2025/26). Il team di analisi, composto dai membri del Gruppo 11, ha ricevuto il mandato esclusivo di valutare l'asset `no_name` operando in un ambiente di laboratorio isolato e controllato.

2.2 Requisiti legali e operativi

Tutte le operazioni offensive sono state condotte nel pieno rispetto del perimetro autorizzato. In alcun modo sono stati effettuati attacchi contro altri asset dell'infrastruttura di rete, accantonando nell'analisi tutti gli indirizzi IP che non corrispondono al target. Il test è stato condotto con l'intento etico di scoprire e sanare le falle di sicurezza, con metodologie tali per cui il team non ha mai violato il perimetro definito negli accordi preliminari.

2.3 Modalità di esecuzione del Penetration Testing

L'attività è stata eseguita secondo un approccio *Black-Box*. Le uniche informazioni fornite dal creatore della macchina `no_name` sono le seguenti:

- La macchina è del tipo **Capture The Flag (CTF)**.
- È possibile eseguire **Privilege Escalation**.

Oltre a ciò il team non disponeva di alcuna conoscenza pregressa sul funzionamento interno del sistema, sul codice sorgente o sulle configurazioni di rete, simulando così le condizioni operative di un reale attaccante esterno.

2.4 Metodologia adottata

L'intero processo di valutazione è stato guidato dal **Framework Generale per il Penetration Testing (FGPT)**. Questo standard metodologico ha garantito un approccio strutturato e riproducibile, scandito in fasi rigorose: dall'*Information Gathering*, passando per il *Target Exploitation*, fino alla *Privilege Escalation*.

2.5 Date di inizio e fine attività

Le operazioni di test, comprensive di ricognizione, exploit e stesura della documentazione, si sono svolte dal 19 maggio 2026 al 16 giugno 2026.

2.6 Obiettivi del test

L'obiettivo primario dell'ingaggio è duplice:

1. Valutare il grado di sicurezza dell'infrastruttura, in particolare fornire una panoramica generale della tenuta e resilienza del sistema e degli applicativi sottostanti in un possibile scenario di attacco da enti malintenzionati.
2. Produrre un report analitico che fornisca ai responsabili IT le linee guida tecniche per la risoluzione definitiva delle vulnerabilità scoperte.

2.7 Ruoli, obblighi e responsabilità

- **Gruppo 11:** Responsabili della conduzione tecnica dei test, dell'identificazione delle vulnerabilità e della stesura del presente report.
- **Committente:** Responsabili della fornitura dell'ambiente di test e della valutazione finale delle metodologie applicate e dei risultati ottenuti.

Capitolo 3

Vulnerability Report

In questa sezione vengono descritte le vulnerabilità identificate durante l'attività di Penetration Testing. Per ciascuna criticità, viene fornita una panoramica generale, l'impatto sulla sicurezza e la valutazione dell'esposizione dell'asset, al fine di far comprendere i rischi operativi anche a un pubblico non strettamente tecnico.

3.1 VULN-01: Command Injection (Esecuzione codice remoto) **CRITICAL**

3.1.1 Descrizione della vulnerabilità

È stata individuata una gravissima vulnerabilità di tipo *Command Injection* all'interno dell'applicazione web, nello specifico nella pagina di amministrazione (`/superadmin.php`). Tale pagina contiene un form che accetta input utente (in particolare un indirizzo IP) per effettuare un test di connettività (*ping*), ma non sono presenti meccanismi di convalidazione e filtraggio abbastanza robusti da bloccare richieste che contengono caratteri speciali.

3.1.2 Impatto sulla sicurezza

L'impatto sulla sicurezza del sistema è **CRITICAL**. Sfruttando questa falla, un utente malintenzionato, tramite iniezione di comandi di sistemi operativi arbitrari (es. Linux), può ingannare il web server ad eseguire operazioni non legittime.

3.1.3 Valutazione esposizione

L'esposizione per l'organizzazione è **MASSIMA**. Tramite questa injection, il team è riuscito ad ottenere una *reverse shell*, ottenendo l'accesso al file system del web server con i privilegi dell'utente *www-data* (l'utente di default del server Nginx). Questa compromissione costituisce il *foothold* ideale per condurre successive attività di *Privilege Escalation*, consentendo di compromettere account con permessi superiori fino all'ottenimento dei diritti di amministratore di sistema (*root*).

3.2 VULN-02: Local Privilege Escalation (Sudoers Misconfiguration) **CRITICAL**

3.2.1 Descrizione della vulnerabilità

Durante la fase di post-sfruttamento (*post-exploitation*), sono state rilevate due gravi negligenze a livello di sistema operativo locale. In primo luogo, un file nascosto appartenente all'utente di sistema

`haclabs` conteneva la sua password salvata in chiaro. In secondo luogo, il file di configurazione dei privilegi (`/etc/sudoers`) autorizzava il suddetto utente ad eseguire il binario di sistema `find` con i massimi privilegi (`root`) senza richiedere l'inserimento di alcuna password.

3.2.2 Impatto sulla sicurezza

L'impatto sulla sicurezza è **CRITICAL**. La combinazione di queste due misconfigurazioni permette a un attaccante, che abbia già ottenuto un accesso base al sistema (ad esempio tramite la VULN-01), di elevare i propri permessi in modo irreversibile. Il comando `find`, infatti, possiede parametri nativi che consentono l'esecuzione di comandi concatenati.

3.2.3 Valutazione esposizione

L'esposizione è **MASSIMA**. Questa vulnerabilità rappresenta l'anello finale della catena di attacco. Sfruttando i privilegi del comando `find`, l'attaccante può forzare il sistema a generare una shell con permessi di amministratore globale (`root`), ottenendo il controllo totale, definitivo e incontrastato sull'intero asset, inclusa la possibilità di alterare i log di sistema per nascondere le proprie tracce.

3.3 VULN-03: CUPS Vulnerability

HIGH

3.3.1 Descrizione della vulnerabilità

Durante la fasi di analisi e mappatura dell'infrastruttura, è stata rilevata l'esposizione al pubblico del servizio di stampa di sistema **CUPS**, nello specifico del demone `cups-browsed` in ascolto sulla porta 631 UDP. Tale servizio risulta affetto da una grave e nota criticità pubblica (CVE-2024-47176), causata dal fatto che il sistema accetta e processa richieste di registrazione senza richiedere alcuna autenticazione o verifica di identità preventiva.

3.3.2 Impatto sulla sicurezza

L'impatto di questa anomalia è **HIGH**. Un utente malintenzionato può inviare pacchetti contraffatti ingannando il server, annunciandosi come una *stampante fittizia* sotto il controllo remoto dell'attaccante. Nel momento in cui il server elabora questi pacchetti o invia una richiesta di stampa alla macchina dell'attaccante, questi può indurre il sistema ad eseguire codice malevolo arbitrario (RCE).

3.3.3 Valutazione esposizione

Le conseguenze operative sono estremamente **SEVERE**. Trattandosi di un demone a livello di sistema operativo, questa vulnerabilità offre una via di accesso diretta all'infrastruttura. Inoltre, il fatto che un servizio locale (come quello di stampa) sia esposto in rete rappresenta una prova concreta di cattiva manutenzione delle configurazioni di sistema, aumentando inutilmente la superficie di attacco.

3.4 VULN-04: Security Misconfiguration

MEDIUM

3.4.1 Descrizione della vulnerabilità

L'analisi automatizzata delle configurazioni del web server ha evidenziato la mancanza di diverse intestazioni (*header*) di sicurezza HTTP fondamentali. Nello specifico, il server non implementa le policy `X-Frame-Options`, `Content-Security-Policy` (CSP) e `Strict-Transport-Security` (HSTS). Tali intestazioni rappresentano lo standard moderno per istruire i browser su come gestire e proteggere i contenuti del sito web.

3.4.2 Impatto sulla sicurezza

L'impatto di questa vulnerabilità è **MEDIUM**. L'assenza delle direttive anti-framing espone l'applicativo ad attacchi di tipo *Clickjacking* (UI Redress Attack), permettendo a un sito malevolo di incorporare le pagine di `no_name` all'interno di *frame trasparenti* (`iframe`) per ingannare l'utente. Inoltre la mancanza di CSP facilita l'esecuzione di script non autorizzati lato client.

3.4.3 Valutazione esposizione

A differenza delle precedenti, l'esposizione diretta dell'infrastruttura del server è praticamente nulla. Tuttavia è da tenere in considerazione che eventuali rischi ricadono direttamente sui client dell'applicazione web. Un malintenzionato potrebbe indurre con l'inganno un operatore legittimo a compiere azioni non volute (come invio di moduli contenenti dati sensibili), **minando la fiducia nel servizio** e compromettendo l'integrità delle sessioni lato client.

3.5 VULN-05: Sensitive Data Exposure (Steganografia) **MEDIUM**

Descrizione della vulnerabilità

L'ispezione approfondita dei contenuti statici e multimediali dell'applicazione ha rivelato una grave leggerezza nella gestione delle informazioni riservate. All'interno di una delle immagini pubblicate sulla pagina di amministrazione primaria (`/admin`), è stata occultata (tramite l'impiego di tecniche di steganografia) una *passphrase* in chiaro. Questo dato nascosto rivela l'indirizzo esatto di un pannello amministrativo di livello superiore e non documentato (`superadmin.php`).

3.5.1 Impatto sulla sicurezza

L'impatto di questa anomalia è **MEDIUM**. Il difetto rientra nella categoria della divulgazione di dati sensibili (*Sensitive Data Exposure*). L'impiego di tecniche di occultamento all'interno di risorse pubbliche vanifica del tutto il paradigma della "Security through Obscurity" (sicurezza tramite oscurità) su cui gli sviluppatori sembrano aver fatto affidamento per proteggere le aree riservate.

3.5.2 Valutazione esposizione

Le conseguenze operative di questa leggerezza sono fatali per l'integrità del sistema. Nascondere informazioni critiche di routing e chiavi di accesso all'interno di file scaricabili da chiunque rappresenta una grave violazione delle best practice. Questa fuga di informazioni agisce come una "mappa" per l'attaccante: rivelando l'indirizzo esatto del pannello `superadmin.php`, gli fornisce un percorso diretto verso il componente più fragile del sistema (facilitando l'esecuzione della *Command Injection* descritta nella VULN-01) e accelerando drasticamente la catena di compromissione.

3.6 VULN-06: Information Disclosure **LOW**

3.6.1 Descrizione della vulnerabilità

Durante la fase di enumerazione condotta tramite lo scanner di rete OpenVAS, è emerso che il sistema operativo del bersaglio risponde attivamente alle richieste di *Timestamp* inoltrate sui protocolli ICMP e TCP. Questa funzionalità, abilitata di default su alcuni vecchi sistemi, permette a chiunque di interrogare l'host per conoscere l'orario di sistema e il tempo di attività continuo (*uptime*) e, in alcuni casi, persino il sistema operativo della macchina.

3.6.2 Impatto sulla sicurezza

L'impatto diretto di questa vulnerabilità è **LOW**, in quanto non consente né l'esecuzione di codice né la modifica di dati. Si tratta di una problematica legata esclusivamente alla divulgazione passiva di informazioni diagnostiche (*Information Disclosure*).

3.6.3 Valutazione esposizione

Sebbene il rischio immediato sia minimo, le conseguenze operative in ottica difensiva non vanno sottovalutate. Fornire l'uptime esatto di una macchina permette a un attaccante di sapere da quanto tempo il server non viene riavviato e, di conseguenza, di dedurre quali patch di sicurezza del kernel manchino all'appello. Tali informazioni tecniche agevolano enormemente l'attaccante nelle fasi di profilazione (*OS Fingerprinting*) e nella selezione accurata degli *exploit* da utilizzare, rendendo gli attacchi successivi molto più mirati ed efficaci.

Capitolo 4

Remediation Report

Questa sezione è destinata al **management e ai responsabili delle policy di sicurezza**. L'obiettivo è tradurre le criticità tecniche emerse in raccomandazioni di sicurezza strutturate (misure correttive e migliorative), al fine di favorire una rapida riduzione del rischio e un rafforzamento complessivo dell'asset.

4.1 Obiettivo

L'obiettivo primario della *remediation* è eliminare i vettori di compromissione diretta (Command Injection e vulnerabilità CUPS) che pongono l'infrastruttura a rischio critico. Contestualmente, si mira a rafforzare la postura difensiva generale eliminando le fughe di informazioni e implementando le *best practice* di configurazione web. Le azioni correttive seguenti sono presentate in rigoroso ordine di priorità.

4.2 Raccomandazioni di sicurezza

4.2.1 VULN-01: Command Injection

Priorità: **CRITICAL**

- **Validazione e Sanitizzazione:** Implementare una rigorosa *whitelist* lato server per controllare i dati in ingresso, rifiutando qualsiasi input che contenga metacaratteri di shell.
- **Refactoring del Codice:** Sostituire le chiamate dirette al sistema operativo (es. esecuzione nativa del comando `ping`) con librerie o API sicure fornite dal linguaggio di programmazione.
- **Privilegio Minimo:** Assicurarsi che l'utente di sistema associato al web server (`www-data`) operi in un ambiente isolato (es. *chroot jail*) e non abbia permessi di lettura/scrittura al di fuori della propria *directory* di competenza.

4.2.2 VULN-02: Local Privilege Escalation

Priorità: **CRITICAL**

- **Bonifica delle Credenziali:** Rimuovere immediatamente il file nascosto contenente la password in chiaro ed effettuare un reset forzato della password dell'account `haclabs`.
- **Hardening del file Sudoers:** Modificare il file `/etc/sudoers` (utilizzando esclusivamente il comando sicuro `visudo`) per rimuovere la direttiva `NOPASSWD` associata al comando `find` per l'utente `haclabs`.
- **Revisione dei Binari (GTFOBins):** Effettuare un *audit* completo di tutti i binari di sistema concessi in esecuzione tramite `sudo`, evitando di assegnare permessi elevati a programmi (come `find`, `tar`, `awk`) che possiedono funzionalità native per l'esecuzione di comandi di *shell*.

4.2.3 VULN-03: CUPS Vulnerability

Priorità: **HIGH**

- **Disabilitazione Servizi Superflui:** Arrestare e disabilitare definitivamente il demone `cups-browsed`, in quanto l'erogazione di servizi di stampa non è pertinente allo scopo di un web server.
- **Hardening di Rete:** Configurare regole rigide sul *firewall* (es. `iptables` o `ufw`) per bloccare tutto il traffico UDP in ingresso sulla porta 631 proveniente da reti esterne.
- **Patching di Sistema:** Applicare tempestivamente gli aggiornamenti di sicurezza rilasciati dal fornitore del sistema operativo per risolvere la vulnerabilità CVE-2024-47176 a livello di pacchetto software.

4.2.4 VULN-04: Security Misconfiguration (Header HTTP)

Priorità: **MEDIUM**

- **Prevenzione Anti-Framing:** Configurare il web server per includere l'intestazione `X-Frame-Options: DENY` per proteggere l'interfaccia dal *Clickjacking*.
- **Content Security Policy (CSP):** Implementare una policy CSP restrittiva per autorizzare esclusivamente l'esecuzione di script provenienti da fonti attendibili e specificate.
- **Forzatura del Traffico Sicuro:** Abilitare l'intestazione `Strict-Transport-Security` (HSTS) per garantire che tutte le future comunicazioni avvengano esclusivamente su canale cifrato.

4.2.5 VULN-05: Sensitive Data Exposure (Steganografia)

Priorità: **MEDIUM**

- **Bonifica degli Asset Pubblici:** Rimuovere immediatamente la *passphrase* occultata dall'immagine e sottoporre a revisione tutti i contenuti multimediali attualmente esposti sul web server.
- **Abbandono della "Security through Obscurity":** Smettere di basare la sicurezza di una pagina (`superadmin.php`) esclusivamente sulla segretezza del suo URL.
- **Controllo degli Accessi:** Implementare un solido meccanismo di autenticazione (credenziali forti e gestione sicura delle sessioni) per l'accesso a qualsiasi area amministrativa del sito.

4.2.6 VULN-06: Information Disclosure (ICMP/TCP Timestamp)

Priorità: **LOW**

- **Disabilitazione ICMP Timestamp:** Modificare le direttive del *kernel* Linux o le regole del *firewall* per ignorare e far cadere in modo silente le richieste ICMP di tipo 13 (Timestamp Request).
- **Filtro TCP Timestamp:** Valutare la disabilitazione dell'estensione TCP Timestamp (`net.ipv4.tcp_timestamps=` se non strettamente necessaria per questioni di misurazione delle prestazioni di rete).
- **Minimizzazione dell'Impronta (Cloaking):** Condurre una revisione generale delle risposte di rete per assicurarsi che il server non riveli informazioni non necessarie (es. versione esatta di Apache o di PHP).

Capitolo 5

Findings Summary

Questa sezione espone le evidenze emerse dall'attività di *penetration testing*, fungendo da ponte tra la visione manageriale dei capitoli precedenti e l'analisi prettamente tecnica e operativa del *Detailed Summary*.

5.1 Convenzioni e catalogazione

Per garantire la massima chiarezza e uniformità di lettura, si illustra di seguito la convenzione adottata per la catalogazione delle vulnerabilità. La severità di ciascuna anomalia è stata classificata utilizzando una scala qualitativa standard di settore, che riflette l'impatto tecnico, l'esposizione al rischio e la facilità di sfruttamento:

Livello di Severità	Descrizione e Impatto Operativo
CRITICAL	Vulnerabilità critica che permette la compromissione totale del sistema o l'esecuzione di codice remoto (RCE) in modo diretto, senza necessità di privilegi pregressi. L'intervento di risoluzione deve essere immediato.
HIGH	Vulnerabilità grave che espone servizi di sistema critici o permette un accesso non autorizzato di alto livello, agevolando l'attaccante nella compromissione dell'asset.
MEDIUM	Vulnerabilità che richiede interazione da parte dell'utente, configurazioni specifiche o che espone dati sensibili (es. credenziali, path nascosti) utilizzabili come vettore per attacchi successivi.
LOW	Vulnerabilità legata alla divulgazione di informazioni diagnostiche o a misconfigurazioni marginali. Presenta un basso impatto diretto sull'integrità del sistema, ma facilita le fasi di ricognizione.

5.2 Dettaglio dei risultati

La seguente tabella riepiloga le evidenze emerse dall'attività di pentesting, ordinate per livello di criticità.

ID	Vulnerabilità	Severità
VULN-01	Command Injection (<code>superadmin.php</code>)	CRITICAL
VULN-02	Local Privilege Escalation	CRITICAL
VULN-03	CUPS Unauthenticated RCE (CVE-2024-47176)	HIGH
VULN-04	Security Misconfiguration (Assenza Header HTTP)	MEDIUM
VULN-05	Sensitive Data Exposure (Steganografia)	MEDIUM
VULN-06	Information Disclosure (ICMP/TCP Timestamp)	LOW

Tabella 5.1: Riepilogo delle vulnerabilità identificate e relativa classificazione.

5.3 Grafici e visualizzazioni

Per offrire una rapida percezione dello stato di salute dell’infrastruttura, il seguente grafico illustra la distribuzione quantitativa delle vulnerabilità identificate, raggruppate per livello di severità.

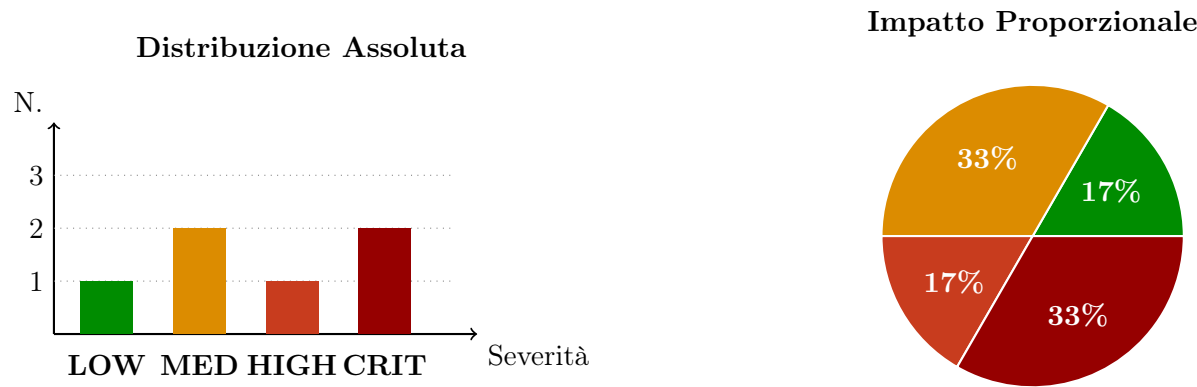


Figura 5.1: Distribuzione assoluta e proporzionale delle vulnerabilità rilevate, suddivise per livello di criticità.

Come si evince dalle metriche, i riscontri si dividono equamente: il 50% si concentra nelle fasce di rischio medio-basso, mentre la massiccia presenza di vulnerabilità di grado **HIGH** e **CRITICAL** (che costituiscono il restante 50% della superficie d’attacco rilevata) sbilancia fortemente il profilo di rischio complessivo verso la compromissione totale dell’asset.

5.4 Focus tecnico

Il focus tecnico dell’analisi rivela che la sicurezza dell’infrastruttura è stata compromessa non da una singola falla isolata, ma da una catena di attacco strutturata (*kill chain*). L’uso improprio della steganografia (VULN-05) ha fornito l’accesso a un’area non documentata, la quale, a causa della totale assenza di *input sanitization* (VULN-01), ha permesso l’esecuzione di una *reverse shell*. Parallelamente, l’infrastruttura di rete si è dimostrata intrinsecamente debole a causa dell’esposizione ingiustificata di demoni di sistema

obsoleti sulla porta 631 UDP (VULN-03) e di una configurazione di rete eccessivamente permissiva (VULN-06).

5.5 Supporto alla remediation

Per fornire contromisure tecniche adeguate e dare più informazioni su come risolvere il problema in modo più tecnico, si raccomanda agli amministratori di sistema di intervenire a due livelli:

1. **Livello Infrastrutturale:** Isolare il web server utilizzando tecnologie di containerizzazione (es. Docker) o *chroot*, e implementare regole *iptables* di *default-deny* per chiudere qualsiasi porta UDP/TCP non strettamente legata al traffico HTTP/HTTPS (es. bloccando la porta 631). Disabilitare inoltre le risposte ai Timestamp modificando i parametri `sysctl`.
2. **Livello Applicativo:** Riscrivere le funzioni PHP che gestiscono l'input in `superadmin.php` utilizzando la libreria `filter_var()` per validare gli indirizzi IP e rimuovere l'uso della funzione `steghide` o simili sui file multimediali esposti.

Capitolo 6

Detailed Summary

In questa sezione viene presentata l'analisi tecnica dettagliata per ogni vulnerabilità rilevata. L'obiettivo è fornire tutte le informazioni necessarie per la catalogazione delle vulnerabilità in maniera precisa e dettagliata.

6.1 Classificazione del rischio

Come illustrato nel *Findings Summary*, le criticità sono catalogate in base al loro impatto tecnico e classificate in CRITICAL, HIGH, MEDIUM e LOW.

6.2 VULN-01: Command Injection

CRITICAL

Modalità di scoperta:

La vulnerabilità è stata identificata inizialmente durante la fase di enumerazione manuale dei form della pagina `superadmin.php`. Successivamente, l'intuizione è stata confermata tramite un approccio a tentativi provando possibili metacaratteri shell che consentissero l'esecuzione di vere e proprie catene di comandi.

Origini e Cause:

L'origine della vulnerabilità risiede nella totale assenza di *input sanitization* nel codice PHP che gestisce la funzione di diagnostica di rete. L'input dell'utente viene concatenato direttamente alla stringa di esecuzione nativa del sistema operativo (es. `shell_exec()`) senza alcun filtraggio dei metacaratteri di concatenazione della shell (nel nostro caso `"|"`).

Rischi e impatti sull'asset:

L'impatto tecnico è devastante. La mancata sanitizzazione permette a un attaccante di "evadere" dal comando originale e concatenare payload malevoli. Durante il test, questo ha permesso l'esecuzione del comando per instaurare una *reverse shell* verso la macchina attaccante, garantendo l'accesso interattivo al file system con i privilegi dell'utente `www-data`.

Contromisure tecniche adeguate:

A livello di codice sorgente, è obbligatorio dismettere le chiamate dirette alla shell. Se l'uso del comando `ping` è strettamente necessario, l'input deve essere validato preventivamente come indirizzo IP legittimo utilizzando funzioni native e sicure (es. `filter_var($ip, FILTER_VALIDATE_IP)` in PHP).

6.3 VULN-02: Local Privilege Escalation (Sudoers Misconfiguration) **CRITICAL**

Modalità di scoperta:

La vulnerabilità è stata scoperta durante la fase di enumerazione locale (*Local Enumeration*) successiva all'ottenimento della *reverse shell*. L'ispezione delle directory utente ha rivelato la presenza del file nascosto contenente le credenziali. Successivamente, dopo aver effettuato un movimento laterale verso l'utente **haclabs**, l'enumerazione dei permessi amministrativi locali ha rivelato i privilegi anomali assegnati al binario **find**.

Origini e Cause:

La criticità origina da un'errata gestione dei permessi amministrativi. L'amministratore di sistema ha concesso i permessi di esecuzione per il binario **/usr/bin/find** ignorando che tale programma rientri nella categoria dei *GTFOBins* (binari di sistema legittimi che possono essere abusati). Nello specifico, **find** possiede il parametro **-exec**, che permette di eseguire un comando shell arbitrario per ogni file trovato.

Rischi e impatti sull'asset:

L'impatto tecnico è la compromissione totale della macchina. L'attaccante può invocare **find** con privilegi di *root* tramite i permessi delegati e passargli come argomento le istruzioni per generare una shell interattiva. Poiché il comando padre gira come *root*, anche il processo figlio erediterà i massimi privilegi.

Contromisure tecniche adeguate:

Oltre alla rimozione del file contenente le password in chiaro, è necessario revocare l'eccezione nel file **/etc/sudoers**. Qualora l'utente **haclabs** necessiti di utilizzare **find** con privilegi elevati per scopi legittimi (es. backup), è obbligatorio implementare script *wrapper* rigidi che non consentano all'utente di passare argomenti arbitrari come **-exec**.

6.4 VULN-03: CUPS Vulnerability (CVE-2024-47176)

HIGH

Modalità di scoperta:

La vulnerabilità è stata inizialmente sospettata tramite una scansione automatizzata condotta con lo strumento Nessus, che ha inviato un payload UDP malevolo ottenendo un riscontro positivo dal target. La reale esposizione del servizio è stata successivamente confermata tramite un'enumerazione manuale mirata del protocollo UDP utilizzando Nmap, che ha validato l'apertura della porta in ascolto sul demone *cups-browsed*.

Origini e Cause:

La criticità deriva da una debolezza intrinseca nel modo in cui il demone *cups-browsed* (fino alla versione 2.0.1) gestisce il protocollo IPP (Internet Printing Protocol). Il servizio è configurato per fare *binding* sull'indirizzo universale **0.0.0.0:631** e accetta pacchetti UDP non autenticati provenienti da qualsiasi fonte, senza implementare alcun meccanismo di validazione dell'identità del mittente.

Rischi e impatti sull'asset:

Un attaccante può sfruttare questa falla inviando un pacchetto UDP forgiato per costringere la macchina bersaglio a registrare una finta stampante IPP controllata dall'esterno. Quando il sistema elabora le direttive PPD (PostScript Printer Description) fornite dall'attaccante per questa finta

stampante, è possibile ottenere l'esecuzione di codice remoto (RCE) nel contesto dell'utente di sistema `lp`, garantendo un punto di accesso indipendente dall'applicazione web.

Contromisure tecniche adeguate:

Si raccomanda l'immediata disabilitazione e disinstallazione del servizio `cups-browsed` tramite il gestore di pacchetti del sistema operativo, in quanto l'infrastruttura analizzata funge da web server e non necessita di funzionalità di stampa. In alternativa, configurare il *firewall* di sistema (es. `iptables`) per effettuare il *drop* selettivo di tutto il traffico UDP diretto alla porta 631.

6.5 VULN-04: Security Misconfiguration (Header HTTP) MEDIUM

Modalità di scoperta:

La problematica è stata rilevata in fase di enumerazione e scansione attiva dell'applicativo web tramite l'utilizzo del *vulnerability scanner* Nikto. L'output del tool (confermato successivamente tramite ispezione visiva e manuale delle risposte HTTP) ha evidenziato in modo inequivocabile la totale assenza di direttive di sicurezza all'interno degli *header* restituiti dal server `no_name`.

Origini e Cause:

L'origine risiede in una configurazione basica e non *hardened* del web server. L'amministratore del sistema non ha esplicitamente dichiarato le direttive `X-Frame-Options`, `Content-Security-Policy` e `Strict-Transport-Security` all'interno del file di configurazione principale (es. `nginx.conf` o `apache2.conf`), lasciando ai browser dei client il compito di decidere come interpretare i contenuti.

Rischi e impatti sull'asset:

L'assenza di `X-Frame-Options` rende l'applicativo vulnerabile al *Clickjacking*, permettendo l'inclusione del sito all'interno di *iframe* malevoli invisibili. La mancanza di CSP non impone alcun vincolo sulle fonti da cui è possibile caricare ed eseguire script lato client, aumentando drasticamente la gravità di potenziali vulnerabilità XSS (Cross-Site Scripting).

Contromisure tecniche adeguate:

Modificare il file di configurazione del web server per includere staticamente le intestazioni di sicurezza in ogni risposta HTTP. Ad esempio, aggiungere la direttiva `add_header X-Frame-Options "SAMEORIGIN"`; per prevenire il framing e implementare una *policy* CSP restrittiva che consenta il caricamento delle risorse unicamente dal dominio locale (`default-src 'self'`).

6.6 VULN-05: Sensitive Data Exposure (Steganografia) MEDIUM

Modalità di scoperta:

L'anomalia è stata identificata mediante l'estrazione e l'analisi dei metadati delle immagini presenti nella directory `/admin`. L'utilizzo di tool di analisi steganografica (`steghide`) ha permesso di estrarre un file di testo occultato all'interno di un'immagine JPG in chiaro.

Origini e Cause:

La vulnerabilità nasce da un errore concettuale di progettazione: la *Security through Obscurity*. Gli sviluppatori hanno deliberatamente nascosto la *passphrase* e la rotta verso il pannello `superadmin.php` all'interno di un file multimediale accessibile pubblicamente, omettendo l'implementazione di controlli di accesso (ACL) o sistemi di autenticazione robusti.

Rischi e impatti sull'asset:

Questa esposizione azzerava completamente il livello di sicurezza del pannello di amministrazione superiore. Fornendo a un potenziale attaccante la posizione esatta e la modalità di accesso alle funzionalità più critiche dell'applicazione, si riducono drasticamente i tempi della *kill chain*, fungendo da vettore facilitatore primario per l'esecuzione della *Command Injection* (VULN-01).

Contromisure tecniche adeguate:

Rimuovere immediatamente l'immagine compromessa dal web server. L'accesso alle aree amministrative deve essere rifattorizzato implementando un sistema di autenticazione a più fattori (MFA) e una robusta gestione delle sessioni PHP, rifiutando esplicitamente qualsiasi richiesta proveniente da utenti non regolarmente autenticati e autorizzati.

6.7 VULN-06: Information Disclosure (ICMP/TCP Timestamp) **LOW**

Modalità di scoperta:

Questa misconfigurazione è stata evidenziata in fase di *Vulnerability Mapping* passiva tramite il tool OpenVAS. Lo scanner ha inviato pacchetti ICMP di tipo 13 (Timestamp Request) e richieste TCP con opzione Timestamp abilitata, ricevendo in entrambi i casi una risposta valida e calcolabile dal target.

Origini e Cause:

L'host bersaglio eredita una configurazione di default del *kernel* Linux, in cui le risposte ai Timestamp TCP (definiti nella RFC 1323) e ICMP sono mantenute attive per scopi storici di diagnostica di rete e calcolo del RTT (Round Trip Time).

Rischi e impatti sull'asset:

Il server comunica involontariamente l'orario del proprio orologio di sistema e, soprattutto, l'esatto *uptime* (il tempo trascorso dall'ultimo riavvio). Un attaccante può utilizzare questa informazione per fare *OS Fingerprinting* avanzato e dedurre con alta precisione se il sistema operativo sia vulnerabile a falle del *kernel* note e recenti, poiché un lungo *uptime* implica matematicamente l'assenza di *patch* critiche che richiedono un riavvio della macchina.

Contromisure tecniche adeguate:

Si richiede l'intervento a livello di *kernel* e *firewall*. Inibire le risposte ICMP bloccando i pacchetti in ingresso di tipo 13 e 14 tramite *iptables*. Disabilitare i Timestamp TCP aggiungendo la direttiva dedicata all'interno del file di configurazione di sistema *sysctl.conf* e ricaricando le policy di sistema.

Capitolo 7

Bibliografia

- [1] National Vulnerability Database (NVD) - NIST, *CVE-2024-47176 Detail - CUPS unauthenticated remote code execution*.
Disponibile all'indirizzo: <https://nvd.nist.gov/vuln/detail/CVE-2024-47176>
- [2] OWASP Foundation, *OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks*.
Disponibile all'indirizzo: <https://owasp.org/Top10/>
- [3] OWASP Foundation, *Command Injection Vulnerability*.
Disponibile all'indirizzo: https://owasp.org/www-community/attacks/Command_Injection
- [4] Gordon Lyon (Fyodor), *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*.
Disponibile all'indirizzo: <https://nmap.org/book/toc.html>
- [5] Greenbone AG, *OpenVAS - Open Vulnerability Assessment Scanner*.
Disponibile all'indirizzo: <https://www.greenbone.net/en/openvas/>
- [6] Tenable, *Nessus*.
Documentazione disponibile all'indirizzo: <https://docs.tenable.com/Nessus.htm>
- [7] CIRT.net, *Nikto Web Server Scanner*.
Disponibile all'indirizzo: <https://cirt.net/Nikto2>